

Отчет по первому этапу индивидуального проекта

Основы информационной безопасности

Осман АлиНиколай

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	17
	Список литературы	18

Список иллюстраций

4.1	Клонирование репозитория	9
4.2	Изменение прав доступа	9
4.3	Перемещение по директориям	9
4.4	Создание копии файла	10
4.5	Открытие файла в редакторе	10
4.6	Редактирование файл	10
4.7	Запуск mysql	11
4.8	Авторизация в базе данных	11
4.9	Изменение прав	11
4.10	Перемещение между директориями	12
4.11	Открытие файла в текстовом редакторе	12
4.12	Редактирование файла	12
4.13	Запуск arche	13
4.14	Запуск веб-приложения	14
4.15	«Создание базы данных»	15
4.16	Авторизация	15
4.17	Домашняя страница DVWA	16

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

1. Установить DVWA на дистрибутив Kali Linux.

3 Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MYSQL.

Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. - Средний — этот уровень безопасности

предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб-приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. **[guide]**

4 Выполнение лабораторной работы

Настройка DVWA происходит на нашем локальном хосте, поэтому нужно перейти в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (рис. 1).

```
(osmanalinikolai@osmanalinikolai)-[~]
$ cd /var/www/html

(osmanalinikolai@osmanalinikolai)-[/var/www/html]
$ sudo git clone https://github.com/ethicalhack3r/DVWA
[sudo] password for osmanalinikolai:
Cloning into 'DVWA' ...
^[[A^[[A^[[A^[[A^[[Afatal: unable to access 'https://github.com/ethicalha
ck3r/DVWA/': Could not resolve host: github.com
```

Рисунок 4.1: Клонирование репозитория

Проверяю, что файлы скопировались правильно, далее повышаю права доступа к этой папке до 777 (рис. 2.)

```
(osmanalinikolai@osmanalinikolai)-[/var/www/html]
$ sudo chmod -R 777 DVWA
```

Рисунок 4.2: Изменение прав доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверяю содержимое каталога (рис. 3)

```
(osmanalinikolai@osmanalinikolai)-[/var/www/html]
$ cd DVWA/config

(osmanalinikolai@osmanalinikolai)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist
```

Рисунок 4.3: Перемещение по директориям

Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. Копируем файл, а не изменяем его, чтобы у нас был запасной вариант, если что-то пойдет не так (рис. 4)

```
(osmanalinikolai@osmanalinikolai)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(osmanalinikolai@osmanalinikolai)-[/var/www/html/DVWA/config]
$ ls
config.inc.php  config.inc.php.dist
```

Рисунок 4.4: Создание копии файла

Далее открываю файл в текстовом редакторе (рис. 5)

```
(osmanalinikolai@osmanalinikolai)-[/var/www/html/DVWA/config]
$ sudo nano config.inc.php
```

Рисунок 4.5: Открытие файла в редакторе

Изменяю данные об имени пользователя и пароле (рис. 6)

```
GNU nano 2.8.6 config.inc.php
?php

# If you are having problems connecting to the MySQL database and all of the
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a
# Thanks to @diginiinja for the fix.

# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED
# Please use a database dedicated to DVWA.
# If you are using MariaDB then you cannot use root, you must use create a database
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'osmanalinikolai';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: '1234567890';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';
```

Рисунок 4.6: Редактирование файл

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 7)

```
(osmanalinikolai@osmanalinikolai)-[/var/www/html/DVWA/config]
$ systemctl status mysql
● mariadb.service - MariaDB 11.8.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; pres>
   Active: active (running) since Sat 2026-03-21 13:20:43 EDT; 10s ago
   Invocation: ed7c103ce7ef40ebb7f53bff2fea7551
     Docs: man:mariadb(8)
           https://mariadb.com/kb/en/library/systemd/
   Process: 9259 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d />
   Process: 9261 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ] >
   Process: 9344 ExecStartPost=/bin/rm -f /run/mysqld/wsrep-start-position >
   Process: 9346 ExecStartPost=/etc/mysql/debian-start (code=exited, status>
   Main PID: 9313 (mariabdd)
   Status: "Taking your SQL requests now..."
   Tasks: 15 (limit: 23470)
  Memory: 156.5M (peak: 161.3M)
```

Рисунок 4.7: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением «MariaDB», далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php (рис. 8)

```
(osmanalinikolai@osmanalinikolai)-[~]
$ sudo mysql -u root -p
[sudo] password for osmanalinikolai:
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-1+b1 from Debian -- Please help get to 10k sta
rs at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement
.

MariaDB [(none)]> create user 'userDVWA'@'127.0.0.1' identified by "dvwa";
Query OK, 0 rows affected (0.008 sec)

MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' id
entified by 'dvwa';
Query OK, 0 rows affected (0.003 sec)
```

Рисунок 4.8: Авторизация в базе данных

Теперь нужно пользователю предоставить привилегии для работы с этой базой данных (рис. 9)

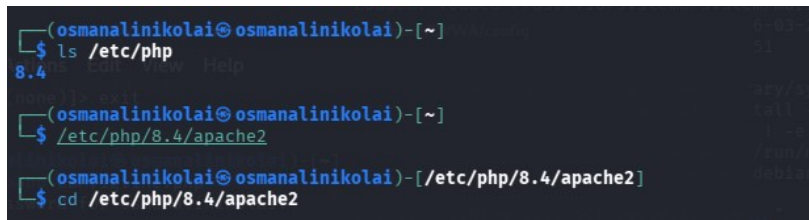
```
MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' id
entified by 'dvwa';
Query OK, 0 rows affected (0.003 sec)

MariaDB [(none)]> exit
Bye
```

Рисунок 4.9: Изменение прав

Необходимо настроить сервер apache2, перехожу в соответствующую директорию

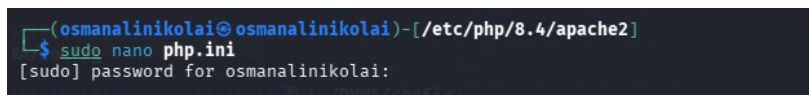
(рис. 10)



```
(osmanalinikolai@osmanalinikolai)-[~]
$ ls /etc/php
8.4
(osmanalinikolai@osmanalinikolai)-[~]
$ /etc/php/8.4/apache2
(osmanalinikolai@osmanalinikolai)-[/etc/php/8.4/apache2]
$ cd /etc/php/8.4/apache2
```

Рисунок 4.10: Перемещение между директориями

В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 11)



```
(osmanalinikolai@osmanalinikolai)-[/etc/php/8.4/apache2]
$ sudo nano php.ini
[sudo] password for osmanalinikolai:
```

Рисунок 4.11: Открытие файла в текстовом редакторе

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как `On` (рис. 12)



```
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as
; https://php.net/allow-url-include
allow_url_include = On
```

Рисунок 4.12: Редактирование файла

Запускаем службу веб-сервера `apache` и проверяем, запущена ли служба (рис. 13)

```
(osmanalinikolai@osmanalinikolai)-[/etc/php/8.4/apache2]
$ sudo systemctl start apache2

(osmanalinikolai@osmanalinikolai)-[/etc/php/8.4/apache2]
$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; pres>
   Active: active (running) since Sat 2026-03-21 13:33:57 EDT; 11s ago
     Invocation: f3480659b2444bce93ee29a29ecbb88e
       Docs: https://httpd.apache.org/docs/2.4/
   Process: 16055 ExecStart=/usr/sbin/apachectl start (code=exited, status=>
    Main PID: 16079 (apache2)
      Tasks: 6 (limit: 3556)
     Memory: 20.9M (peak: 21.1M)
        CPU: 93ms
     CGroup: /system.slice/apache2.service
            └─16079 /usr/sbin/apache2 -k start
              └─16082 /usr/sbin/apache2 -k start
                └─16083 /usr/sbin/apache2 -k start
                  └─16084 /usr/sbin/apache2 -k start
                    └─16085 /usr/sbin/apache2 -k start
                      └─16086 /usr/sbin/apache2 -k start

Mar 21 13:33:57 osmanalinikolai systemd[1]: Starting apache2.service - The A>
Mar 21 13:33:57 osmanalinikolai systemd[1]: Started apache2.service - The Ap>
lines 1-20/20 (END)
```

Рисунок 4.13: Запуск apache

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя 127.0.0/DVWA (рис. 14)

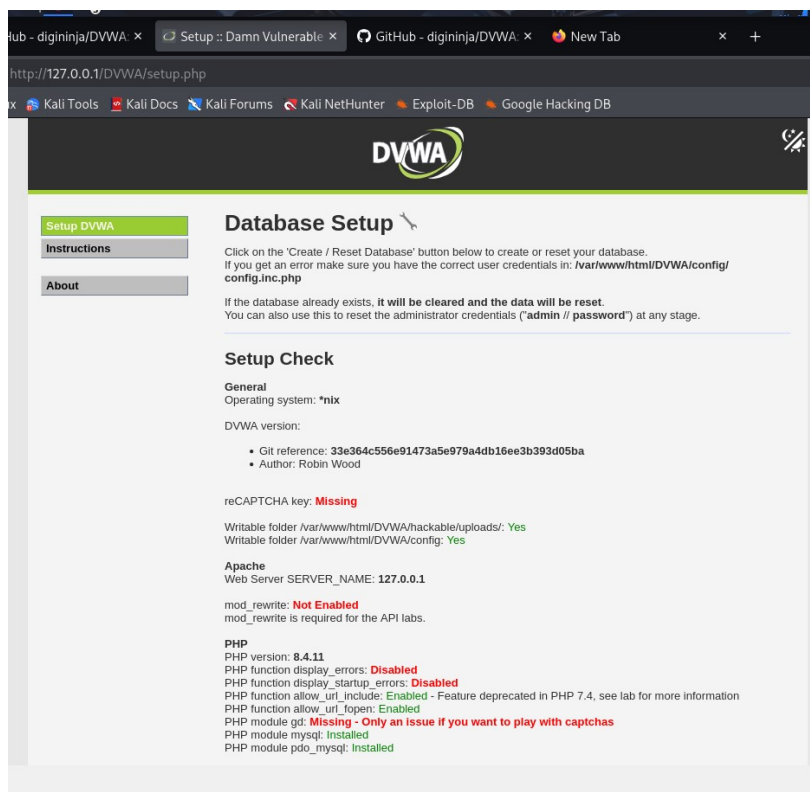


Рисунок 4.14: Запуск веб-приложения

Прокручиваем страницу вниз и нажимаем на кнопку create\reset database (рис. 15)

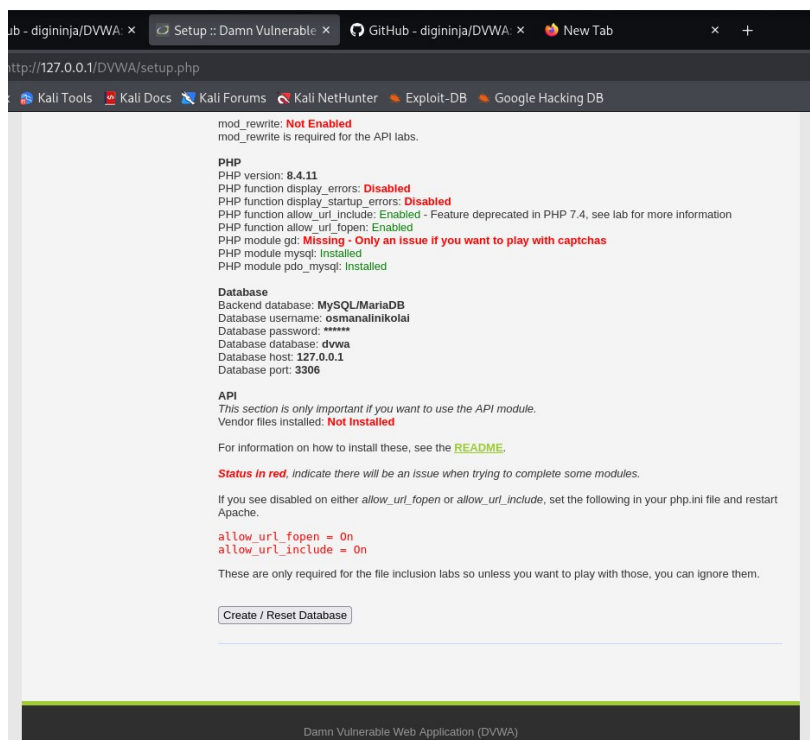


Рисунок 4.15: «Создание базы данных»

Авторизуюсь с помощью предложенных по умолчанию данных (рис. 16)



Username

Password

Login

Рисунок 4.16: Авторизация

Оказываюсь на домашней странице веб-приложения, на этом установка окончена

(рис. 17)

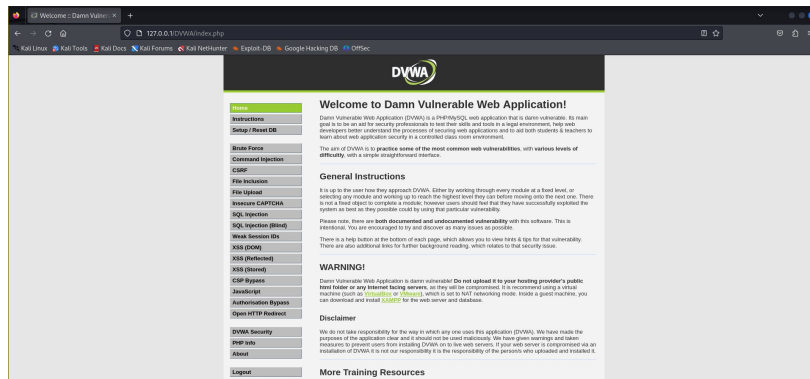


Рисунок 4.17: Домашняя страница DVWA

5 Выводы

Приобрела практические навыки по установке уязвимого веб-приложения DVWA.

Список литературы